

Security+ 1.4 · Hashing & Digital Signatures

Mestre CyberSec — PDF baseado na aula do Professor Messer · 1.4 — Hashing & Digital Signatures (10:24)

· [vídeo original ↗](#) · [YouTube ↗](#)

Hash = impressão digital mão única: SHA-256/SHA-3 padrão; MD5/SHA-1 quebrados.
Assinatura digital = cifrar o hash com a chave PRIVADA — qualquer um valida com a pública. Garante integridade + autenticidade + non-repudiation (3 objetivos).

Highlights que a prova cobra

- SHA-256 padrão; MD5/SHA-1 quebrados (collision)
- Assinatura = hash cifrado com chave PRIVADA de quem assina
- Avalanche effect: 1 bit mudou = hash inteiro mudou

Dicas de prova

- 'provides integrity but not confidentiality' = hash
- 'cannot deny that they signed' = digital signature (non-repudiation)

Cenário clássico: Cenário: 'arquivo é verificado com SHA-256 depois do download pra confiar que não foi alterado' = integridade por hash.

Perguntas de treino (10 questões)

Gabarito no fim. Tenta responder SEM olhar.

1. Pra garantir que um arquivo NÃO foi alterado (integridade), tu usa:

- A)** Compressão ZIP
- B)** Função hash (ex: SHA-256)
- C)** Criptografia AES
- D)** Assinatura Base64

2. Uma característica de HASH (diferente de criptografia) é que ele:

- A)** Pode ser revertido com a chave
- B)** É de mão única (não reversível)
- C)** Sempre encurta o texto pela metade
- D)** Precisa de par de chaves

3. A forma correta de ARMAZENAR senhas de usuários:

- A)** Hash com salt (ex: bcrypt)
- B)** Criptografia AES reversível
- C)** Texto claro protegido por firewall
- D)** Base64

4. Qual função criptográfica NÃO é reversível?

- A)** Criptografia AES
- B)** Criptografia RSA
- C)** Hash SHA-256
- D)** Codificação Base64

5. Cenário corporativo (Hashing & Digital Signatures): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'SHA-256 padrão; MD5/SHA-1 quebrados (collision)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: SHA-256 padrão; MD5/SHA-1 quebrados (collision)...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Hashing & Digital Signatures): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'Assinatura = hash cifrado com chave PRIVADA de quem assina'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Assinatura = hash cifrado com chave PRIVADA de quem assina...

7. Cenário corporativo (Hashing & Digital Signatures): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'Avalanche effect: 1 bit mudou = hash inteiro mudou'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Avalanche effect: 1 bit mudou = hash inteiro mudou...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Hashing & Digital Signatures): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'provides integrity but not confidentiality' = hash'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'provides integrity but not confidentiality' = hash...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Hashing & Digital Signatures): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'cannot deny that they signed' = digital signature (non-repudiation)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'cannot deny that they signed' = digital signature (non-repudiation)...

10. Cenário corporativo (Hashing & Digital Signatures): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'Cenário: 'arquivo é verificado com SHA-256 depois do download pra confiar que não foi alterado' = integridade por hash.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Cenário: 'arquivo é verificado com SHA-256 depois do download pra confiar q...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO

- 1) B — Função hash (ex: SHA-256).** Hash gera uma 'impressão digital'; se um bit muda, o hash muda. SHA-256 é padrão. AES dá confidencialidade, não integridade por si só.
- 2) B — É de mão única (não reversível).** Hash é one-way: não dá pra 'descriptografar' de volta. Por isso serve pra guardar senha (compara hashes) e checar integridade.
- 3) A — Hash com salt (ex: bcrypt).** Senha se guarda como HASH salgado (bcrypt/argon2) — não reversível. Nunca em texto claro nem cripto reversível (a chave vaza junto).
- 4) C — Hash SHA-256.** Hash (SHA-256, MD5) é função unidirecional (one-way) - não pode ser revertida para recuperar o dado original. Criptografias são reversíveis com a chave correta.
- 5) A — Implementar a solução correspondente: SHA-256 padrão; MD5/SHA-1 quebrados (colli).** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Hashing & Digital Signatures): SHA-256 padrão; MD5/SHA-1 quebrados (collision). As demais alternativas configuram violações graves de c
- 6) D — Implementar a solução correspondente: Assinatura = hash cifrado com chave PRIVAD.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Hashing & Digital Signatures): Assinatura = hash cifrado com chave PRIVADA de quem assina. As demais alternativas configuram violações
- 7) B — Implementar a solução correspondente: Avalanche effect: 1 bit mudou = hash intei.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Hashing & Digital Signatures): Avalanche effect: 1 bit mudou = hash inteiro mudou. As demais alternativas configuram violações graves d
- 8) B — Implementar a solução correspondente: 'provides integrity but not confidentialit.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Hashing & Digital Signatures): 'provides integrity but not confidentiality' = hash. As demais alternativas configuram violações graves
- 9) D — Implementar a solução correspondente: 'cannot deny that they signed' = digital s.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Hashing & Digital Signatures): 'cannot deny that they signed' = digital signature (non-repudiation). As demais alternativas configuram
- 10) C — Implementar a solução correspondente: Cenário: 'arquivo é verificado com SHA-256.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Hashing & Digital Signatures): Cenário: 'arquivo é verificado com SHA-256 depois do download pra confiar que não foi alterado' = integr